**AGENSI KESELAMATAN SIBER NEGARA (NACSA)**

**ARAHAN KETUA EKSEKUTIF NO. 9**

# PENYEDIAAN DATA DAN MAKLUMAT PELAKSANAAN MIGRASI KRIPTOGRAFI PASCA KUANTUM OLEH ENTITI INFRASTRUKTUR MAKLUMAT KRITIKAL NEGARA

Pada menjalankan kuasa yang diberikan di bawah seksyen 13 Akta Keselamatan Siber 2024 [Akta 854], Ketua Eksekutif Agensi Keselamatan Siber Negara (NACSA) membuat arahan seperti yang berikut:

## TUJUAN

1. Arahan ini bertujuan untuk—

    1.1 mengenal pasti tahap ketersediaan inventori kriptografi terhadap risiko ancaman pengkomputeran kuantum bagi memastikan migrasi kriptografi pasca kuantum (*post-quantum cryptography*, PQC) dilaksanakan mengikut keutamaan;

    1.2 memastikan entiti infrastruktur maklumat kritikal negara menyediakan data dan maklumat bagi pelaksanaan migrasi PQC;

    1.3 memastikan setiap ketua sektor infrastruktur maklumat kritikal negara, berkenaan dengan sektor infrastruktur maklumat kritikal negara yang baginya ia dilantik, melaksanakan penyelarasan dan pemantauan bagi penyediaan data dan

maklumat pelaksanaan migrasi PQC oleh entiti infrastruktur maklumat kritikal negara dalam sektor infrastruktur maklumat kritikal negaranya; dan

1.4 menetapkan Pusat Teknologi dan Pengurusan Kriptologi Malaysia (PTPKM) sebagai penyelaras di bawah penyeliaan NACSA bagi mengumpul data dan maklumat pelaksanaan migrasi PQC yang disediakan oleh entiti infrastruktur maklumat kritikal negara bagi tujuan analisis dan pelaporan strategik kepada NACSA.

**LATAR BELAKANG**

2. Akta Keselamatan Siber 2024 [Akta 854] telah diluluskan oleh Parlimen pada 3 April 2024 dan telah mendapat perkenan oleh Kebawah Duli Yang Maha Mulia Seri Paduka Baginda Yang di-Pertuan Agong Sultan Ibrahim pada 18 Jun 2024. Akta 854 kemudiannya telah disiarkan dalam *Warta* pada 26 Jun 2024.

3. Selaras dengan subseksyen 1(2) Akta 854, YAB Perdana Menteri selaku Menteri yang dipertanggungkan dengan tanggungjawab bagi keselamatan siber, telah menetapkan 26 Ogos 2024 sebagai tarikh Akta 854 mula berkuat kuasa.

4. YAB Perdana Menteri juga telah menetapkan 26 Ogos 2024 sebagai tarikh kuat kuasa bagi peraturan-peraturan yang dibuat dibawah Akta 854 seperti yang berikut:

4.1 Peraturan-Peraturan Keselamatan Siber (Tempoh bagi

Penilaian Risiko Keselamatan Siber dan Audit) 2024 [*P. U. (A) 219/2024*];

4.2 Peraturan-Peraturan Keselamatan Siber (Pemberitahuan Insiden Keselamatan Siber) 2024 [*P.U. (A) 220/2024*];

4.3 Peraturan-Peraturan Keselamatan Siber (Pelesenan Pemberi Perkhidmatan Keselamatan Siber) 2024 [*P.U. (A) 221/2024*]; dan

4.4 Peraturan-Peraturan Keselamatan Siber (Pengkompaunan Kesalahan) 2024 [*P.U. (A) 222/2024*].

5. Peraturan-Peraturan di atas telah disiarkan dalam *Warta* pada 22 Ogos 2024.

6. Perenggan 10(1)*(f)* Akta 854 memperuntukkan bahawa Ketua Eksekutif NACSA hendaklah mempunyai kewajipan untuk mengeluarkan arahan kepada ketua sektor infrastruktur maklumat kritikal negara, entiti infrastruktur maklumat kritikal negara, Entiti Kerajaan atau mana-mana orang lain mengenai perkara yang berhubungan dengan keselamatan siber negara.

7. Subperenggan 14(1)*(a)*(A) hingga (B) Akta 854 seterusnya memperuntukkan seperti berikut:

"**Kuasa untuk mengumpul maklumat**

**14**. (1) Walau apa pun mana-mana undang-undang bertulis lain, jika Ketua Eksekutif mempunyai alasan yang munasabah untuk mempercayai bahawa mana-mana orang—

*(a)* mempunyai apa-apa maklumat, butir-butir atau dokumen yang berkaitan dengan pelaksanaan kewajipan dan kuasa Ketua Eksekutif di bawah Akta ini; atau

*(b)* berupaya untuk memberikan apa-apa keterangan yang Ketua Eksekutif mempunyai alasan yang munasabah untuk mempercayai adalah berkaitan dengan pelaksanaan kewajipan dan kuasa Ketua Eksekutif di bawah Akta ini,

Ketua Eksekutif boleh, melalui notis secara bertulis, mengarahkan orang itu—

(A) supaya memberikan apa-apa maklumat atau butir-butir sedemikian kepada Ketua Eksekutif mengikut bentuk dan cara dan dalam tempoh sebagaimana yang dinyatakan dalam notis itu atau apa-apa tempoh lanjutan sebagaimana yang diberikan oleh Ketua Eksekutif;

(B) supaya mengemukakan apa-apa dokumen sedemikian, sama ada dalam bentuk fizikal atau media elektronik, kepada Ketua Eksekutif mengikut cara dan dalam tempoh sebagaimana yang dinyatakan dalam notis itu atau apa-apa tempoh lanjutan sebagaimana yang diberikan oleh Ketua Eksekutif;".

8. Arahan ini dikeluarkan selaras dengan kuasa yang diberikan kepada Ketua Eksekutif NACSA di bawah subperenggan 14(1)*(a)*(A) hingga (B) Akta 854 dibaca bersama dengan kewajipan

dan kuasa Ketua Eksekutif NACSA di bawah perenggan 10(1)*(f)* Akta 854.

**PROSEDUR BERHUBUNG DENGAN PENYEDIAAN DATA DAN MAKLUMAT PELAKSANAAN MIGRASI PQC OLEH ENTITI INFRASTRUKTUR MAKLUMAT KRITIKAL NEGARA**

9. Entiti infrastruktur maklumat kritikal negara hendaklah melaksanakan penyediaan data dan maklumat pelaksanaan migrasi PQC yang digunakan merangkumi sistem, aplikasi, perkhidmatan dan infrastruktur maklumat kritikal negara masing-masing.

10. Semua data dan maklumat yang disediakan tersebut hendaklah diberikan dan dikemukakan kepada Ketua Eksekutif NACSA mengikut bentuk dan cara sebagaimana yang dinyatakan dalam notis secara bertulis oleh Ketua Eksekutif NACSA dalam tempoh **tiga (3) bulan** dari tarikh notis tersebut.

11. Data dan maklumat yang perlu dikemukakan adalah sepertimana yang dinyatakan di dalam **Borang Pelaksanaan Migrasi PQC** di **Lampiran A**.

**PEMAKAIAN ARAHAN**

12. Arahan ini hendaklah terpakai kepada PTPKM, semua ketua sektor infrastruktur maklumat kritikal negara dan entiti infrastruktur maklumat kritikal negara.

**KUAT KUASA ARAHAN**

13. Arahan ini berkuat kuasa pada 22 September 2025.

**(IR. DR. MEGAT ZUHAIRY BIN MEGAT TAJUDDIN)**

Ketua Eksekutif

Agensi Keselamatan Siber Negara (NACSA)

Majlis Keselamatan Negara

Jabatan Perdana Menteri

**LAMPIRAN A**

# BORANG PELAKSANAAN MIGRASI PQC

**Nota:**

1. Pengisian data dan maklumat hendaklah merujuk Buku Kerja Bengkel Migrasi PQC.
2. Setiap entiti infrastruktur maklumat kritikal negara (NCII) boleh mengemukakan data dan maklumat tambahan selain daripada data dan maklumat asas yang dinyatakan dalam borang ini.

## A. Inventori Kriptografi NCII

### 1. Jadual 0 – *Initial Inventory for PQC Readiness*

Mengenal pasti semua aset berkaitan kriptografi termasuk perkakasan, perisian tegar, sistem pengendalian, aplikasi, dan perkhidmatan. Ia merupakan langkah pertama sebelum analisis *Software Bill of Materials* (SBOM) dan *Cryptographic Bill of Materials* (CBOM).

| No. | Nama Aset/ *Identifier* | Lokasi/ Pemilik | Fungsi *Cryptographic tersedia*? | Contoh Algoritma yang digunakan | SBOM/CBOM tersedia? | Aras Ketersediaan Migrasi | Nota/ Item Tindakan |
|---|---|---|---|---|---|---|---|
| 1. | **Contoh:** VMware ESXi 7.x | Virtualisation Stack | Ya | AES, RSA | Tidak | Rendah | Check vendor crypto support |
| 2. | | | | | | | |

## 2. Jadual 1 – *Software Bill of Materials* (SBOM)

Menyenaraikan komponen perisian yang digunakan dalam sistem yang dikenal pasti dalam Jadual 0, dengan tumpuan kepada penggunaan kriptografi dalam *libraries* dan pakej perisian.

| No. | Sistem / Aplikasi | Tujuan/ Penggunaan | URL | Mod Perkhidmatan | Sasaran Pelanggan | Komponen Perisian | *Modul Third-party* | *External APIs* / Perkhismatan | Aras Kritikal | Kategori Data | Adakah sistem/ Aplikasi sedang digunakan | Pembangun Sistem/ Aplikasi | Nama vendor | Adakah Agensi mempunyai kepakaran | Adalah agensi mempunyai peruntukan khas? | Putan ke CBOM |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| 1. | **Contoh:** E-mail Gateway | | | Online | G2C | OpenSSL 3.0.2, Log4j 2.17.1 | Custom Login Module, Spring Security | Google Maps API, MyIdentity (SSO) | Sangat Tinggi | Sulit | Ya | Vendor | | Tidak | Ya | CBOM #1 |
| 2. | | | | | | | | | | | | | | | | |

## 3. Jadual 2 – *Cryptographic Bill of Materials* (CBOM)

Menyenaraikan secara terperinci mengenai fungsi kriptografi, algoritma yang digunakan, dan alternatif PQC yang dicadangkan bagi setiap komponen perisian.

| No. | # (CBOM) | Sistem/ Aplikasi | Fungsi *Cryptographic* | Algoritma yang digunakan | *Library*/ Modul | Panjang Kunci | Tujuan/ Penggunaan | Sokongan *Crypto-Agility* |
|---|---|---|---|---|---|---|---|---|
| 1. | **Contoh:** CBOM #1 | E-mail Gateway | Digital Signature | RSA-2048 | OpenSSL | 2048-bit | Email signing (S/MIME) | Ya |
| 2. | | | | | | | | |

## B. Penilaian Risiko dan Kebergantungan

### 1. Jadual 3 – *Risk Register*

Membantu mengenal pasti potensi risiko yang berkaitan dengan migrasi PQC.

| Bil. | Nama Sistem/ Perkakasan/Perisian | Jenis Aset Aplikasi/Perkakasan/Perisian | Algoritma Kriptografi | Kegunaan Algoritma Kriptografi | Tahap Kritikal | Risiko | Pemilik Risiko |
|---|---|---|---|---|---|---|---|
| 1. | **Contoh:**<br>Sistem Emel Dalaman | | RSA-2048, SHA-1 | Tandatangan Digital | Kritikal | Ketidakserasian Sistem Legacy dengan PQC | BPM, TM |
| 2. | | | | | | | |

### 2. Jadual 4 – *Risk & Dependency Assessment*

Membantu menilai potensi impak jika *legacy cryptography* terus digunakan, serta *dependency* antara sistem dan komponen.

| Bil. | Nama Sistem/ Perkakasan/ Perisian | Algoritma Kriptografi | Risiko | Punca Risiko | Impak | Kemungkinan (*Likelihood*) | Skor Risiko | *Risk Level* | Kawalan Sedia Ada | Pelan Mitigasi |
|---|---|---|---|---|---|---|---|---|---|---|
| 1. | **Contoh:**<br>Sistem Emel Dalaman | RSA-2048, SHA-1 | Ketidakserasian Legacy System dengan PQC | Sistem/aplikasi sedia ada tidak menyokong algoritma PQC | 5 | 5 | 25 | Risiko Sangat Tinggi | Penilaian awal keserasian sistem | Ujian integrasi sistem PQC dan pelan mitigasi keserasian |
| 2. | | | | | | | | | | |

## C. Rangka Tindakan Awal Migrasi PQC

### 1. Pelan Garis Masa Migrasi PQC Mengikut Fasa

Garis masa ini membantu organisasi merangka garis masa awal untuk migrasi PQC mengikut lima fasa kebangsaan: *Assess, Select, Validate, Deploy* dan *Monitor.* Ini adalah bertujuan untuk memastikan organisasi merancang sumber dengan lebih teratur dan memastikan aktiviti migrasi dijalankan mengikut keutamaan. Oleh itu, organisasi diminta untuk membentangkan pelan migrasi merangkumi aktiviti utama bagi setiap fasa yang disesuaikan dengan keperluan masing-masing.

| Fasa | Tempoh Sasaran (Bulan/Tahun) | Aktiviti Utama | Catatan Tambahan |
|---|---|---|---|
| Fasa 1: Persediaan (*Assess*) | **Contoh:**<br>Jul – Dis 2025<br>(Maksimum 6 Bulan) | | |
| Fasa 2: Pemilihan (*Select*) | **Contoh:**<br>Jan – Jun 2026<br>(Maksimum 6 Bulan) | | |
| Fasa 3: Pengesahan (*Validate*) | **Contoh:**<br>Jul – Dis 2026<br>(Maksimum 6 Bulan) | | |
| Fasa 4: Pelaksanaan (*Deploy*) | **Contoh:**<br>Jan – Jun 2027<br>(Maksimum 6 Bulan) | | |
| Fasa 5: Pemantauan (*Monitor*) | **Contoh:**<br>Julai 2027+ | | |

## 2. Keperluan Sumber dan Sokongan

Maklumat ini bertujuan untuk mengenal pasti keperluan sumber manusia, teknikal dan kewangan yang diperlukan bagi menyokong pelaksanaan migrasi PQC. Perancangan sumber yang jelas membantu memastikan setiap aktiviti dapat dilaksanakan dengan lancar dan mengikut jadual.

| Bil. | Item/Keperluan | Perincian/Tujuan | Anggaran Kos (RM) | Nota Tambahan |
|---|---|---|---|---|
| 1. | Latihan dan kesedaran | | | |
| 2. | Perolehan teknologi baharu | | | |
| 3. | Pengujian dan penilaian | | | |
| 4. | Khidmat perundingan/Audit | | | |
| 5. | Kos operasi/Penyelenggaraan | | | |
| 6. | Lain-lain | | | |